



Secure development and technical vulnerability management policy

This document is property of Data & More ApS and commercial in confidence. The document is intended to be read with the permission of Data & More ApS only. If you do not have explicit permit to read the document, stop reading the document and contact the document owner immediately.

David Junge

using Cyberday.ai

28.09.2026, 09:54

Version #7

Introduction

Secure development policy describes how the organization develops software applications and components in a way that ensures a good level of built-in security.

Secure development contributes to the security of the whole environment by ensuring that many technical vulnerabilities are avoided in the design, development and testing phases, before new written code can be deployed into live environments affecting the company production, customers or both.

This policy describes the safeguards and precautions during the software development lifecycle to control related risks and in their part facilitate the original business cases for the software to be achieved.

Security tasks are tasks assigned to ISMS users on organization's information security management system.

Employee guidelines are general guidelines related to using company information in a secure way. Guidelines are assigned to all employees or selected units and their acceptance is monitored automatically through organization's ISMS.

Security tasks

Security tasks related to secure development describe the core team's responsibilities in relation to development and testing environment, change management, managing vulnerabilities and controlling outsourced work.

Secure development

Approval from the data owner for using production data for testing purposes

The organization must obtain approval from the owner of the information, and manage potential risks, before using it for testing purposes.

Description

The task owner ensures that production data is not used for testing or other purposes, without approval is obtained from the data owner and the data protection risks associated with the processing are identified, assessed, and documented.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Automated secure code deployment and release

The organization must define the means for a secure software deployment strategy. Means should be automated if possible.

Description

D&M has implemented following measures for safe deployment of code:

- Involved teams have clear roles and responsibilities in the deployment process
- Approved deployment and automation technologies have been listed
- Teams have been authorized to address security issues when needed

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Built in and default cyber security in system development (Security by design)

The organization must create procedures that by default cyber security and security requirements are considered from the start when developing and designing new systems, digital services or business processes.

This is called the principle of built-in and default security (security by design). As a result of this approach, the design documentation should clearly indicate what measures are taken to ensure cyber security.

Description

Data & More Development Process document describe how this is archived.

See:

<https://docs.google.com/document/d/1fyW5QAYnNUgDPt3qerepWapP6Zde1Gp148SbD64qpFQ/edit?tab=t.0#heading=h.86mtjivjsqo1>

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 16.10: Apply Secure Design Principles in Application Architectures...

Built in and default data protection in systems development (Privacy by design)

The organization has to create procedures for having data protection, correct way of processing personal data and compliance with data protection requirements by default in all new systems, digital services or in planning and development of new procedures from the start.

This is called principle of privacy by design. Important part of applying this principle is configuring systems default settings so that they minimize processing of personal data and follow all regional laws and regulations.

Description

Implementing Privacy by Design (PbD) in the D&M Compliance System (DMCS) involves embedding privacy considerations into every aspect of the system's lifecycle. Here's how we've operationalized PbD principles in DMCS:

1. Proactive and Preventative Measures

We conduct early - stage Privacy Impact Assessments (PIAs) to identify and mitigate potential privacy risks before they materialize. This proactive approach ensures that privacy considerations are integral from the outset of system development.

2. Privacy as the Default Setting

DMCS is designed to collect and process only the data necessary for its functions. By default, data collection is minimized, and retention periods are strictly defined, ensuring that personal data is protected without requiring user intervention.

3. Privacy Embedded into Design

Privacy controls are integrated into the core architecture of DMCS. This includes implementing encryption, access controls, and data anonymization techniques to safeguard personal information throughout the system.

4. Full Functionality – Positive - Sum, Not Zero - Sum

We strive to achieve a balance where privacy and functionality coexist without compromising each other. For instance, DMCS allows for comprehensive data analysis while ensuring that individual privacy is not infringed upon.

5. End-to-End Security – Lifecycle Protection

Data protection measures are applied throughout the entire data lifecycle in DMCS. From initial collection to final deletion, data is secured using encryption, secure storage, and controlled access protocols .

6. Visibility and Transparency

We maintain transparency by providing clear information about data processing activities within DMCS. Users are informed about what data is collected, how it's used, and their rights regarding their personal information .

7. Respect for User Privacy – User-Centric Approach

DMCS empowers users by providing them with control over their data. Features such as consent management, data access requests, and easy-to-understand privacy settings ensure that users can manage their personal information effectively .

By integrating these principles, DMCS not only complies with regulatory requirements like the GDPR but also fosters trust and confidence among its users by prioritizing their privacy at every step .

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Change management procedure for significant changes to data

processing services

Inadequate change management is a common cause of incidents for digital services.

An organization shall document the change management process that must be followed whenever significant changes are made to developed digital services or other computing services that affect cyber security. **The process includes requirements e.g. for the following:**

- Defining and documenting the change
- Assessing the risks and defining the necessary control measures
- Other impact assessment of the change
- Testing and quality assurance
- Managed implementation of the change
- Updating a change log

Description

Significant changes and related impact assessments are documented in the organization's cyber security management system.

Task owner regularly reviews the list of assessments performed and the results produced to ensure that they are adequate and consistent.

Assurance:



Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked section:

Change risk assessments 3 in total

3 total • 2 described • 1 risks

Linked requirements:

NIST Cybersecurity Framework V2.0 - ID.RA-07: Changes and exceptions...

+6 requirements

Definition of done and testing principles

The development unit itself maintains a list of criteria that need to be met before a task can be marked as completed. The criteria may include e.g. review requirements, documentation requirements and testing requirements.

New code will only be implemented after extensive testing that meets pre-defined criteria. Tests should cover usability, security, effects on other systems, and user-friendliness.

Description

The development unit itself maintains a list of criteria that need to be met before a task can be marked as completed. The criteria may include e.g. review requirements, documentation requirements and testing requirements.

New code will only be implemented after extensive testing that meets pre-defined criteria.

Tests should cover usability, security, effects on other systems, and user-friendliness.

Assurance:

 Medium

Priority:

High ↑

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.29: Security testing in development and acceptance...

+4 requirements

Designing Secure Software Development Life Cycle(SSDLC) process

The organization shall define and implement a Secure Software Development Life Cycle (SSDLC) process in software development.

The first step in the SSDLC process should be to define security requirements that ensure that security considerations become integrated into the services being developed right from the creation phase.

It is recommended that the SSDLC process include at least the following steps:

- A - Training
- B - Description of the requirements
- C - Design
- D - Development
- E - Security testing
- F - Publication
- G - Responding to issues

Description

According to a document from March 2025, D&M has implemented a **Secure Software Development Life Cycle (SSDLC)** process that is comprehensive, structured, and deeply integrated with risk and security considerations across all phases of development. The process is both standards-aligned and designed for adaptability across different development methodologies such as waterfall and agile.



Phases of the SSDLC

D&M's SSDLC is composed of six primary phases, each with defined security practices and responsibilities:

1. Requirements Analysis

- **Risk Assessment:** Each project initiates with a security-focused risk analysis.

- **Security & Compliance Review:** Evaluation of confidentiality, integrity, and availability needs, as well as alignment with regulations like GDPR and internal policies.
- **Stakeholder Alignment:** Includes customer - partner interface planning and approval of security requirements and budgets.

2. Architecture and Design

- **Security Architecture Development:** Teams are educated on secure system design principles.
- **Security Controls Identification:** Technical and non-technical controls are defined early.
- **Review & Documentation:** High-level security designs and segregation of duties are formalized. Security testing plans and training requirements are also defined here.

3. Development

- **Secure Environment Setup:** Dedicated environments are configured with hardened security settings.
- **Security Component Coding:** Developers are required to implement application-level security modules.
- **Tracking & Testing Infrastructure:** Integration with vulnerability tracking and test automation platforms is established.

4. Testing

- **Static and Dynamic Code Analysis:** Both automated and manual code reviews are conducted to detect vulnerabilities.
- **System and Load Testing:** Includes performance evaluation with security controls in place.
- **Independent Assessments:** External or internal teams validate infrastructure and application security posture.

5. Deployment/Implementation

- **Pilot Deployment:** Infrastructure and applications are deployed in a staged manner.
- **Integrity Verification:** File system integrity checks and system authenticity verifications are mandated.

- **Dual Developer Sign-off:** Full deployment requires the approval of at least two developers to reduce risk.

6. Operations and Maintenance

- **Continuous Monitoring:** Post-deployment, systems are monitored for vulnerabilities and anomalies.
- **Patch and Upgrade Strategy:** Regular updates are managed with a focus on minimizing disruption while maximizing security.
- **Re-entry Into Design:** Major changes loop back into earlier SDLC phases to ensure proper design consideration.

Additional Security Controls

- **Use of Live Test Data Restrictions:** Only approved environments may use realistic datasets.
- **Tooling & Automation:** Integration with platforms like Git, SonarCloud, and Dependabot ensures real-time scanning, testing, and validation before release.
- **Training and Awareness:** Developers undergo mandatory security onboarding and periodic refreshers to stay aligned with evolving threats.

Standards Alignment

The SSDLC process follows NIST 800-64 Rev. 2 and incorporates guidance from the ACSC (Australian Cyber Security Centre), ensuring alignment with international best practices.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIST Cybersecurity Framework V2.0 - PR.PS-06: Secure software development practices...

+4 requirements

Documentation of security metrics related to application security

The organization must specifically document security metrics that measure the level of application security. Implementation must take into account the organization's own security objectives as well as other security requirements.

Description

D&M has defined the following as security metrics that describe application security:

- Vulnerabilities Detected
- Average Repair Time
- Number of critical vulnerabilities
- Automated testing and scan coverage

A list of security metrics is maintained in the organization's digital security management system. The owner of the task is responsible for the timeliness of the listing and the owners assigned to the meters are responsible for documenting the measurement results.

Assurance:



Strong

Priority:

High ↑

Status:

Fully done

Owner:

DJ D. Junge

Due diligence in the selection of software components

The organization is undertaking the due diligence process when selecting software components so that these components do not affect the cyber security of the product with digital elements. Due diligence is carried out for all components, including components provided by third parties as well as free and open-source software components that have not been released to the market in connection with commercial activity. Due diligence includes, for example, checking the quality of the components, the track record of the supplier of the component and the security of the component itself. The results of the due diligence process are clearly documented.

Description

According to the 2025 *D&M Security Measures and Protocols* and supported by development standards in the *Development Framework*, **Data & More (D&M)** applies a rigorous due diligence process when selecting third-party software components to ensure they do not compromise the cybersecurity posture of products containing digital elements—particularly the **D&M Compliance Server (DMCS)**.



Selection and Vetting of Software Components

D&M's approach includes:

1. Use of Proven, Public-Domain Software

D&M uses components from reputable open-source projects and vendors such as:

- **Docker, Ubuntu, Elastic, Kibana, PostgreSQL, NGINX, RabbitMQ, Kafka, Grafana**, among others
- These components are **publicly maintained and auditable**, which allows validation against known security standards and vulnerabilities.

2. Automated Dependency Management

- **Dependabot** is used to continuously monitor and flag outdated or vulnerable dependencies in the software stack.
- The **Team Lead is explicitly responsible** for validating dependencies during peer review (Stage 10 in the SDLC).

Continuous Vulnerability Monitoring

- D&M **continuously monitors** third-party software for vulnerabilities using tools like **Sonarcloud.io**, which scans source code and dependencies for malicious patterns or risky behaviors.
- Updates to third-party libraries are bundled as part of the **normal release cycle**, with releases planned to include **patches or replacements for affected components**.
- This process is **governed by a change management policy** and reviewed in **bi-weekly security meetings** to evaluate and track vulnerabilities.

Technical Safeguards at Integration

- Each Docker container is configured to allow only **approved input/output operations**, reducing dependency attack surface.
- Shared Docker mount points are **avoided or strictly controlled** to prevent privilege escalation or unauthorized data access.
- Hash values of container images are registered and verified post-deployment to ensure **code integrity and authenticity**.

Summary

D&M ensures secure use of software components through:

- **Pre-selection of widely validated third-party tools**
- **Automated dependency scanning and alerting**
- **Mandatory dependency validation during code review**
- **Bi-weekly governance reviews** to assess risk impact
- **Secure container design and runtime validation**

This due diligence process ensures that all software components included in D&M products—particularly DMCS—are **vetted, monitored, and integrated with security-first principles**, minimizing cybersecurity risks throughout the product lifecycle.

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.5: Due diligence

Encryption of public network traffic for application services

Information included in application services transmitted over public networks must be protected against fraudulent and non - contractual activity and against unauthorized disclosure and alteration.

We use strong encryption and security protocols (eg TLS, IPSEC, SSH) to protect confidential information when it is transmitted over public networks in connection with the IT services we develop.

Description

When application services are accessed through a web browser, all network traffic is encrypted using the SSL protocol.

All domains managed by the organization are forced to use HTTPS.

Connections to servers managed by the organization are encrypted using either SSH or HTTPS protocol.

Assurance:



Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27018 - A.11.6: Encryption of PII transmitted over public data-transmission networks...

+5 requirements

Encryption of user password information

We use strong encryption during password transmission and storage in all services we develop.

Description

User passwords are not stored in a dedicated data system (e.g. Auth0) .

The amount of password information in the services is provided by O365 and minimized by integrating secure and commonly used authentication methods to the offered by Office 365.

In addition, own employees are provided with a password management system and passwords may not be stored in other locations.

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.5: Secure authentication...

+4 requirements

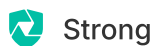
Establishing and managing an inventory of third-party software components

The organization creates a centralized bill of materials (BOM) repository to manage third-party components, including detailed information, tracking, regular updates, risk assessments, vulnerability monitoring, and facilitate communication with development teams for proactive security management.

Description

D&M manage an inventory of third-party software components is a critical practice for ensuring software security, compliance, and operational stability.

Assurance:



Strong

Priority:

Normal

Status:

Fully done

Owner:

K k.

Linked requirements:

CIS 18 - 16.4: Establish and Manage an Inventory of Third-Party Software Components

Establishing change management procedures

As part of the safeguards to preserve the availability, authenticity, integrity, and confidentiality of data, organization's should develop and implement robust change management procedures. These procedures must apply to all changes related to software, hardware, firmware components, ICT systems, and security parameters. The procedures must include the following critical elements:

- Conduct a formal verification process to ensure that all ICT security requirements have been met before any change is approved or implemented.

- The team requesting and implementing a change is independent from the team reviewing and approving the change, to prevent conflicts of interest and ensure objectivity.

Ensure there is a clear assignment of roles and responsibilities, covering:

- Specification and planning of changes
- Design of an adequate transition, ensuring operational continuity
- Controlled testing and finalization of the change
- Effective quality assurance throughout the change lifecycle.

Document and communicate the following details for every change:

- Purpose and scope of the change
- Timeline for implementation
- Expected outcomes of the change
- Fallback procedures and responsibilities, including: procedures for aborting a change and plans for recovering from failed or partial implementations.

Include specific protocols for handling urgent situations:

- Define emergency change procedures that still provide adequate safeguards despite their expedited nature.

Ensure that all emergency changes (including workarounds and patches): are documented, are re-evaluated and assessed post-implementation and undergo formal approval after deployment.

Procedure should also include a security impact assessment for each proposed change to identify its potential impact on existing ICT security measures.

Description

Robust change management procedures are established and maintained for all changes related to software, hardware, firmware components, ICT systems, and security parameters. A formal verification process is conducted to ensure all ICT security requirements are met before any change is approved or implemented. The teams requesting and implementing changes are independent from those reviewing and approving them to ensure objectivity.

Roles and responsibilities are clearly assigned for the specification and planning of changes, design of adequate transitions for operational continuity, controlled testing and finalization, and effective quality assurance throughout the change

lifecycle. For every change, the purpose, scope, timeline, expected outcomes, and fallback procedures are documented and communicated, including plans for aborting changes or recovering from failures.

Specific protocols are in place for handling urgent situations, with emergency change procedures providing adequate safeguards despite their expedited nature. All emergency changes, including workarounds and patches, are documented, re-evaluated, assessed post-implementation, and undergo formal approval after deployment. A security impact assessment is performed for each proposed change to identify its potential impact on existing ICT security measures.

Assurance:

 **Medium**

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

DORA RTS Risk management framework - Article 17: ICT change management

General rules for reviewing and publishing code

General rules for reviewing, approving and publishing the code have been defined and enforced.

The rules may include e.g. the following things:

- the generated code has been validated against the general safe development guidelines of the OWASP Framework
- the code has been reviewed by at least two people
- the changes have been approved by a designated, authorized user prior to publication

- the system documentation has been updated before release
- the time of publication of the changes has been chosen in accordance with the given instructions in order to minimize disruption to business processes
- the instructions needed by users have been updated before the code is released

The rules are intended to manage the risks associated with the release of new program code.

Description

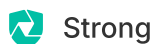
General rules for reviewing, approving and publishing the code have been defined and enforced.

The rules include e.g. the following things:

- The generated code has been validated against the general safe development guidelines of the OWASP Framework
- The code has been reviewed by at least two people
- The changes have been approved by a designated, authorized user prior to publication
- The system documentation has been updated before release
- The time of publication of the changes has been chosen in accordance with the given instructions in order to minimize disruption to business processes
- The instructions needed by users have been updated before the code is released

The rules are intended to manage the risks associated with the release of new program code.

Assurance:



Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked section:

1 development guidelines

accepted

Linked requirements:

ISO 27001/27002:2022 - 8.28: Secure coding...

+3 requirements

Guidelines for secure development

The general rules for secure development work have been drawn up and approved by the development managers. The implementation of the rules is monitored in software development in the organization and the rules are reviewed at least yearly.

The safe development policy may include e.g. the following things:

- safety requirements of the development environment
- instructions for secure coding of the programming languages used
- safety requirements at the design stage of properties or projects
- secure software repositories
- version control security requirements
- the skills required from developers to avoid, discover and fix vulnerabilities
- compliance with secure coding standards

Compliance with the rules of secure development may also be required of key partners.

Description

The general rules for secure development work have been drawn up and approved by the development managers

Assurance:



Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked section:

Secure development and technical vulnerability management policy  Report

Linked requirements:

CIS 18 - 16.1: Establish and Maintain a Secure Application Development Process...
+10 requirements

Listing authorized users for publishing code changes

Only pre-defined, authorized users are allowed to post changes to the code.

Description

Only pre-defined, authorized users are allowed to post changes to the code.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.30: Outsourced development...
+3 requirements

Maintaining a release log

An event log should be kept for all updates to production or customer software or in-house IT services.

Description

All changes are documented in git + the slack change log.

New releases are created from stage via git actions , and the release number are printed in slack

Documents from i gDrive describes the changes and a distributed to stakeholders

Assurance:

 **Strong**

Priority:

Low ↓

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.19: Installation of software on operational systems

Privacy by Design and privacy by default

Description

See: https://docs.google.com/document/d/1xt5Bzi3_W5MssOHiygi2-rroWfrks_dFfxSZ0G6OkOQ/edit?tab=t.0

Assurance:

 **Medium**

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27701 - A.8.4: Privacy by design and privacy by default

Processing which does not require identification

We do not process data which does not require identification

Description

We do not process data which does not require identification

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

KH K. Boe Helweg

Linked requirements:

General data protection regulation - 11: Processing which does not require identification

Protection and minimisation of test data

The data and other materials used for testing should be carefully selected and protected.

Production information that contains personal or other confidential information should not be used for testing purposes.

Description

All testing is performed in a staging environment with its own minimized database. Test data does not include production data, customer - managed information, or other confidential information.

Task owner is responsible for ensuring these principles are met when the database used by the test environment needs to be updated or more test data needs to be created.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIS2 - 21.2.e: Secure system acquisition and development...
+4 requirements

Regular critical code identification and verification

The definition of security - critical code for the various services is maintained. New parts of the critical code are constantly being identified and new updates are being checked particularly closely for changes to the critical code. The aim is to keep the likelihood of security vulnerabilities to a minimum.

Description

New parts of the critical code are constantly being identified and new updates are being checked particularly closely for changes to the critical code. The aim is to keep the likelihood of security vulnerabilities to a minimum.

Assurance:

 Medium

Priority:

Low ↓

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 16.1: Establish and Maintain a Secure Application Development Process...

+5 requirements

Restoration strategy

We have agreed and recorded policies to restore an earlier version of the software before implementing the releases.

Description

We have agreed and recorded policies to restore an earlier version of the software before implementing the releases.

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked section:

Secure development and technical vulnerability management policy  Report

Linked requirements:

ISO 27001/27002:2022 - 8.32: Change management

Safe running of unknown code

All code of unknown origin must be executed in a so-called sandbox environment, i.e. isolated from other devices and networks in the organization. This prevents it from accessing the organization's resources without special permission from the user. This includes:

- Other software in its own sandboxes
- Databases that store images or documents, for example
- Peripheral devices such as cameras, microphones and GPS
- Access to the local network.

Description

The task owner creates and manages a sandbox environment where unknown code can be run securely.

The sandbox environment is isolated into its own network and has no contact with any other network in use. The environment includes a virtual server and a user's desktop environment for testing.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - MWP-06: Safe running of unknown code...

+2 requirements

Secure setting and distribution of temporary login information

Temporary credentials should be unique and should not be guessable, for example, by inferring from user data.

Description

Task: Secure Setting and Distribution of Temporary Login Information

Objective: To establish a secure method for generating, delivering, and managing temporary login credentials that cannot be reused, ensuring the confidentiality and integrity of user accounts.

Key Requirements:

One - Time Password (OTP) Generation:

- Implement a robust algorithm (e.g., HMAC -based One - Time Password (HOTP) or Time -based One - Time Password (TOTP)) to generate unique, unpredictable OTPs.
- Ensure that each OTP is valid for a limited time to prevent unauthorized access.

Secure Delivery:

- Choose a secure channel to transmit OTPs to users (e.g., SMS, email, push notifications, or authenticator apps).
- Employ encryption or other security measures to protect OTPs during transmission.
- Consider factors like network latency and user preferences when selecting the delivery method.

User Authentication:

- Require users to enter both their username or email address and the corresponding OTP during the login process.
- Validate the OTP against the generated sequence to verify the user's identity.

Revocation Mechanism:

- We have implement a system to invalidate OTPs immediately after they are used or if a security breach is suspected.

- This prevents unauthorized access even if an OTP is intercepted.

User Experience:

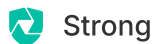
- We provide clear instructions to users on how to generate and use OTPs.
- Offer alternative authentication methods (e.g., biometrics) for users who may face challenges with OTPs.

Security Best Practices:

- Regularly update security protocols and algorithms to address evolving threats.
- Educate users about security best practices, such as avoiding sharing OTPs and being wary of phishing attempts.
- Monitor for signs of unauthorized access or breaches and take immediate action.

By following these guidelines, we can significantly enhance the security of their login processes and protect user accounts from unauthorized access.

Assurance:



Priority:

Low ↓

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

ISO 27001/27002:2022 - 5.17: Authentication information

Security in the product development process

The organization has defined a development process that includes appropriate cybersecurity aspects of product design, development and production. The level of cybersecurity required for a product should be defined based on risk level and assessments. The process should include at least:

- security requirements of the product
- security reviews during the implementation
- testing of security and functions
- documentation of security tasks

Description

According to a document from March 2025, **Data & More (D&M)** follows a well-defined **Secure Software Development Lifecycle (SSDLC)** that tightly integrates cybersecurity best practices into **each phase of product design, development, and production**. The approach ensures the security, resilience, and regulatory compliance of all developed systems and services.

Overview of the Secure Development Lifecycle at D&M

D&M's SSDLC is composed of multiple stages—**requirements analysis, architecture and design, development, testing, deployment, operations/maintenance, and decommission**—with cybersecurity measures embedded at each phase.

1. Requirements Phase

- **Security and regulatory analysis:** Requirements are evaluated against internal standards, GDPR, and other relevant frameworks.
- **Risk assessment:** Each feature or service undergoes a documented risk analysis to identify confidentiality, integrity, and availability (CIA) impacts.
- **Security budgeting and planning:** D&M factors security implementation costs into early planning and evaluates "buy vs. build" decisions for security services.

2. Architecture and Design Phase

- **Security - by - design** principles: Security controls (technical and procedural) are defined up front.
- **Role segregation:** Design includes strict separation of duties between development, testing, and production environments.
- **Documentation:** Technical security designs and residual risk mitigation strategies are recorded.
- **Training & awareness planning:** Development of security training programs for users and developers begins here.

3. Development Phase

- **Secure environments:** Development and test infrastructures are segregated and configured securely.
- **Secure coding:** Developers implement application - level security components with ongoing peer reviews.
- **Vulnerability tracking:** Tools and workflows are set up to monitor and act on security issues across builds.
- **Security testing plans:** Created for both current and future versions, covering unit and regression testing.

4. Testing Phase

- **Static and dynamic code analysis:** Used to identify security vulnerabilities at the code and config level.
- **System hardening tests:** Performance, load, and usability tests are conducted with security controls enabled.
- **Independent security assessments:** External or independent vulnerability tests are required for critical systems.

5. Deployment Phase

- **Pilot to full - scale transition:** Carefully managed, with integrity checks and validation of system authenticity.

- **Security training:** Targeted sessions for admins and users on how to use and protect the deployed systems.
- **Dual-developer sign-off:** At least two developers must authorize deployments to production, reducing insider threat and accidental misconfiguration risk.

6. Operations & Maintenance

- **Routine patching and hardening:** Security updates are tracked and applied based on severity and exposure.
- **Monitoring and logging:** Continuous operational oversight ensures anomalies are detected and acted upon.
- **Audit and compliance:** Periodic reviews ensure controls function effectively and logs meet audit requirements.

7. Decommission Phase

- **Secure system retirement:** Includes final integrity checks, user access reviews, and secure data handling.
- **Documentation updates:** All procedures and designs are revised to reflect system status and lessons learned.

Summary

D&M's development process integrates cybersecurity **from the ground up**, applying best practices across all lifecycle stages. Key strengths include:

- Early risk identification and mitigation
- Secure architecture and environment isolation
- Formal vulnerability assessment and patching cycles
- Enforced code review and testing processes
- Security training embedded into both dev and user onboarding

These measures ensure that every product brought to market is **secure by design, resilient in operation, and compliant with data protection standards**.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.1): Appropriate level of cybersecurity

Separation of production, testing and development environments

Software under development, testing and production is run in differentiated technical environments in order to ensure the quality of development work in an environment that adapts to the production environment and, on the other hand, the production environment is not disturbed by unfinished development.

Sensitive or personal data of users is not copied and used in a development environment.

Description

Development work is divided into three distinct development stages and environments:

- New code is written locally in the development environment of the developer's own workstation
- Once the code is written and tested by the developer, the code is published in its own test branch, which can be run in a staging environment
- once the code has been user and security tested, and the necessary fixes have been made, the code change can be released to production environment

Assurance:

 Medium

Priority:

High 

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIST Cybersecurity Framework V2.0 - PR.DS-02: Data-in-transit is protected...

+10 requirements

Source code management

Access to source code and other related plans is controlled to prevent e.g. adding unauthorized code and avoiding unintentional changes. Access rights are allocated on a need-to-know basis and, for example, support staff are not granted unlimited access rights.

Source code control can be implemented, for example, by storing all code centrally in a dedicated source code management system.

Description

All software code and related information (plans, drawings, descriptions, etc.) is managed centrally in a software code management system (e.g. GitLab). Access to the various code repositories is granted only on a need-to-know basis.

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.4: Access to source code...

+3 requirements

Specific safeguards for production data used for testing

The use of production data for testing purposes should be avoided. If confidential information is used in testing, the following security measures should be used:

- all sensitive details should be either deleted or made secure (e.g. anonymisation of personal data)
- testing environments are subject to the same strict access control as production
- copying production data to the test environment is done only with a separate authorization
- production data is removed from the test environment immediately upon completion of testing

Assurance:

 Weak

Priority:

Low ↓

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIS2 - 21.2.e: Secure system acquisition and development...

+3 requirements

Stress testing after major changes

Following significant changes to their ICT systems, central counterparties (CCPs) and central securities depositories (CSDs) must submit their ICT systems to stringent testing under simulated stressed conditions. This is critical to ensure that systems continue to perform reliably, securely, and resiliently under adverse or extreme circumstances.

Central Counterparties (CCPs) must, as appropriate, involve the following stakeholders in both the design and conduct of the stress testing:

- Clearing members and clients,
- Interoperable central counterparties,
- Other interested parties (e.g., relevant service providers or market participants impacted by the CCP's operations).

Central Securities Depositories (CSDs) must, as appropriate, involve the following stakeholders in the design and conduct of the stress testing:

- Users of the CSD services,
- Critical utilities and critical service providers supporting operational or infrastructure needs,
- Other central securities depositories,
- Other market infrastructures (such as trading venues or payment systems),
- Any other institutions identified in the CSD's ICT business continuity policy as having operational interdependencies.

Description

Following significant changes to the organization's ICT systems, stringent testing under simulated stressed conditions is conducted.

This ensures that systems continue to perform reliably, securely, and resiliently, especially considering the organization's focus on digital privacy and data security in the IT & Software industry.

The design and conduct of this stress testing involve key stakeholders, including clients and relevant service providers, to accurately reflect real-world scenarios and interdependencies.

Assurance:



Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

DORA RTS Risk management framework - Article 17: ICT change management

Technical documentation for products

Before placing a product with digital elements on the market, The organization draws up the technical documentation required by Article 31. We have documented the following information related to the product:

- description of the product
- technical specifications of the product
- intended use of the product
- list of the components of the product (if appropriate)
- design documentation of the product
- results of quality control and assurance procedures, including the results of conformity assessment procedures (if appropriate)

We have designated the person responsible for the technical documentation and the person who has reviewed the technical documentation before placing the product on the market.

Description

D&M create technical documentation required by Article 31. We have documented the following information related to the product:

- description of the product
- technical specifications of the product
- intended use of the product
- design documentation of the product

We have designated the person responsible for the technical documentation and the person who has reviewed the technical documentation before updating DMCS.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.12: Technical documentation

Technical vulnerability management

Anticipating capacity-related problems

The operation of information systems may depend on certain key resources, such as *server capacity*, *file storage capacity*, *data processing capacity*, *monitoring capacity* or certain *key persons*.

In particular, some of these resources may have long delivery times or high costs in certain situations, in which case special attention must be paid to future capacity problems with them.

We monitor the use of key system resources and identify trends, potential security bottlenecks and dependencies on important people.

Description

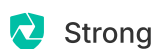
Monitoring key resources: The organization continuously monitors key resources pivotal to the operation of information systems. These may include server capacity, file storage capacity, data processing capacity, monitoring capacity, or key personnel.

Addressing potential capacity issues: The organization pays attention to potential future capacity problems, especially for resources with long delivery times or high costs. Proactive planning and effective resource management strategies are employed to prevent operational disruptions.

Identifying trends and bottlenecks: The organization vigilantly identifies trends in system resource utilization. It recognizes potential bottlenecks that might hamper system performance or security, devising strategies to alleviate these issues before they cause significant effects.

Identifying dependencies on key persons: The organization understands its reliance on essential personnel for system operations. It identifies these dependencies and ensures that contingency plans are in place to prevent disruptions due to sudden personnel unavailability.

Assurance:



Strong

Priority:

Normal

Status:

Fully done

Owner:

LL L. Lopusina

Linked requirements:

ISO 27001/27002:2022 - 8.6: Capacity management...
+5 requirements

Assessments for defining the scope for threat-led penetration testing (TLPT)

Organization carries out threat-led penetration testing. Each test needs to cover multiple critical or important functions of the related financial entity.

To properly define the proportionate scope for TLPT:

- Financial entities shall identify relevant ICT systems, processes and technologies supporting critical or important functions
- Financial entities shall assess which of these need to be covered by the TLPT

The result of this assessment shall determine the precise scope of TLPT and shall be validated by the competent authorities.

Description

Organization carries out threat-led penetration testing. Each test needs to cover multiple critical or important functions of the related financial entity.

The result of this assessment shall determine the precise scope of TLPT and shall be validated by the competent authorities.

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

The Digital Operational Resilience Act (DORA) - Article 26: Advanced testing of ICT tools, systems and processes based on TLPT...

+2 requirements

Authorized users and rules for installing software and libraries

Unmanaged installations of software on computers can lead to vulnerabilities and security breaches.

The organization should determine what types of software or updates each user can install. **The instructions may include e.g. the following guidelines:**

- only specially designated persons may install new software on the devices
- programs previously designated as secure may be installed by anyone
- use of certain software may be impossible for everyone
- existing software updates and security patches are allowed to be installed by anyone

Description

Restrictions on software installations: The organization has defined the types of software or updates each user can install on their devices. This helps in controlling unmanaged installations, reducing vulnerabilities, and maintaining tight security.

Installation by designated personnel: In the organization, only specially designated individuals are allowed to install new software on the devices. This restriction ensures that unauthorized or potentially malicious software is not installed.

Installation of pre-approved software: The organization has a list of pre-approved, secure software which can be installed by any user. This supports productivity while still maintaining control over software installations.

Prohibition of certain software: The organization has identified specific software that is prohibited for installation. This helps prevent potential security risks associated with malicious or vulnerable software applications.

Software updates and security patches: The organization allows any user to install updates and security patches for existing software. This promotes keeping software up-to-date, optimizing performance, and reducing the risk of security breaches.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - SUM-02: Keeping licensed software up to date...

+6 requirements

Automating the handling of technical vulnerabilities

The organization must develop a process to automate the treatment of technical vulnerabilities.

Description

Development of automated vulnerability treatment process: The organization has developed a process that automates the treatment of technical vulnerabilities. This reduces the manual effort, improves speed, and increases consistency in addressing vulnerabilities.

Integration of vulnerability management tool: The organization has integrated a vulnerability management tool that automates the task of identifying, classifying, prioritizing, and mitigating vulnerabilities.

Implementation of patch management automation: The organization has implemented an automated patch management system. This system identifies the need for patches, tests them in a non-production environment, and deploys them on systems, all in an automated manner.

Assurance: **Strong****Priority:**

Normal

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

CIS 18 - 7.7: Remediate Detected Vulnerabilities

Conducting automated vulnerability scans of externally -exposed enterprise assets

The organization conducts monthly automated vulnerability scans on all externally -exposed assets, utilizing advanced tools for thorough analysis and prompt response to findings, while regularly updating scanning protocols to address emerging threats and maintain security vigilance.

Description

D&M conducts monthly automated vulnerability scans on all externally -exposed assets, utilizing advanced tools for thorough analysis and prompt response to findings, while regularly updating scanning protocols to address emerging threats and maintain security vigilance.

Assurance: **Medium****Priority:**

Normal

Status:

Fully done

Owner:

K k.

Linked requirements:

CIS 18 - 7.6: Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets

Conducting automated vulnerability scans of internal enterprise assets

The organization has implemented a comprehensive strategy for automated vulnerability scans of internal assets, conducting both authenticated and unauthenticated scans with thorough coverage and regular analysis of results, and continuously enhancing tools and techniques based on findings to address security risks.

Description

D&M has implemented a comprehensive strategy for automated vulnerability scans of internal assets, conducting both authenticated and unauthenticated scans with thorough coverage and regular analysis of results, and continuously enhancing tools and techniques based on findings to address security risks.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

K k.

Linked requirements:

CIS 18 - 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets

Consideration of threat intelligence findings in the information security risk management process

Organization must consider the threat intelligence process findings in the information security risk management process. Threat intelligence can detect, for example, the proliferation of certain types of attacks or the development of new technologies, based on which assessments of certain information security risks must be updated, which may lead to the need to reduce risks through treatment plans.

Description

Integration of threat intelligence findings: The organization has considered the findings of the threat intelligence process in the information security risk management process. This approach ensures a holistic understanding of potential security threats.

Detection of attack patterns: The organization has put in place systems which use threat intelligence to detect patterns of certain types of attacks. This enables proactive management of these threats before they cause harm.

Assurance:

 Strong

Priority:

Low 

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

ISO 27001/27002:2022 - 5.7: Threat intelligence...
+3 requirements

Defining metrics related to vulnerability management

The organization needs to define Monitored Metrics for identifying and correcting vulnerabilities. Meters must be monitored at specified intervals.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked section:

5 cyber security metrics

answered 100%

Linked requirements:

CIS 18 - 16.2: Establish and Maintain a Process to Accept and Address Software Vulnerabilities

Establishing and maintaining a severity rating system for application vulnerabilities

The organization develops a detailed severity rating system for vulnerabilities, defining criteria for severity levels, integrating these ratings into development workflows, setting security standards, using automated assessment tools, establishing a triage process, and reviewing the system annually to ensure effective vulnerability management.

Description

Application Vulnerability Severity Rating System

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 16.6: Establish and Maintain a Severity Rating System and Process for Application Vulnerabilities

Hardening of virtual machines utilized in cloud service offering

Hardening is the practice of reducing system vulnerability by reducing its attack surface.

When configuring virtual machines the organization has to make sure the machines are hardened by, for example, only using ports, protocols and services that are needed. There must also be technical security measures like anti-malware and logging enabled for all virtual machines.

Description

Adoption of system hardening practice: The organization has adopted the practice of system hardening, thus reducing system vulnerabilities by minimizing its attack surface.

Configuration of virtual machines: As part of its hardening practice, the organization ensures that its virtual machines are set up with minimal usage of ports, protocols, and services. This approach reduces potential entry points for attacks.

Technical security measures implementation: The organization has implemented technical security measures such as anti-malware installations and comprehensive logging on all virtual machines. This ensures robust protection and monitoring of system activities.

Hardening guidelines and standards adherence: The organization follows established hardening guidelines and standards. This adherence to industry best practices ensures that systems are configured optimally for security.

Assurance:



Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

ISO 27017 - CLD 9.5.2: Virtual machine hardening...

+2 requirements

Initial treatment of identified technical vulnerabilities

We have defined the rules for responding to identified vulnerabilities. **The rules may include e.g. the following things:**

- who are part of a quick-response team that is ready to respond to vulnerabilities
- the person locating the vulnerability immediately informs the entire team down the agreed channel
- the team determines the severity of the vulnerability (low, medium, high) based on predefined criteria
- the team decides whether to continue processing as a security breach (more urgently) or under general change management
- the necessary individuals are selected to continue addressing the vulnerability

Vulnerabilities related to high-risk data systems are always of high severity and are addressed first.

Description

Quick-response team setup: The organization has determined the composition of a quick-response team that is primed to respond to identified vulnerabilities. This team is made up of individuals with the requisite skills and expertise to promptly and effectively tackle such issues.

Reporting process for located vulnerabilities: Upon locating a vulnerability, the concerned individual is tasked with promptly informing the entire team through an agreed-upon channel. This ensures that all team members are promptly aware and can begin coordinated response efforts.

Determining vulnerability severity: The team assesses the severity of the vulnerability (low, medium, high) based on pre-defined criteria. This categorization aids in prioritizing response actions and allocating resources effectively.

Deciding response approach: Based on the assessed severity, the team decides whether to handle the vulnerability as a security breach (necessitating more urgent attention) or under general change management. This decision informs the timeline and intensity of the response efforts.

Choosing individuals for vulnerability management: The organization selects the necessary individuals to continue addressing the vulnerability, considering roles, skills, and availability. The selected individuals then collaborate to rectify the vulnerability and reinstate secure operations.

Addressing high-risk data system vulnerabilities: Vulnerabilities related to high-risk data systems are always considered of high severity. The organization prioritizes addressing these vulnerabilities first, given their potential impact on data security and system functionality.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.8: Management of technical vulnerabilities...

+6 requirements

Minimizing the risk of attack by limiting attack surfaces

The organization must limit the risk of attack from external interfaces and the likelihood of vulnerabilities being used on products. They should do this by:

- Limiting the number of external interfaces: if the organization has a dedicated server for a particular application, the task that this server performs should not be expanded. The application should not be extended to do things other than those intended and for which it was developed.
- Limiting the number of ports used: the organization must strive for minimal use of ports.
- Limiting the number of devices with external interfaces: to minimize the attack surface, the organization must limit the number of devices connected to the external network.
- Using secure and robust systems: the organization must ensure that all systems used have been developed with security in mind.

Description

Paste into Cyberday

Implementation statement

Data & More limits attack risk from external interfaces by keeping each system single-purpose, opening only the ports required for that purpose, restricting which hosts are reachable from the internet, and running hardened, security-designed platforms (CIS-aligned OS/container stack, Ansible-managed configuration, encrypted management paths). Changes that would expand a host's role, open new inbound ports, or add internet-facing devices follow change control and are recorded in our ISMS (Cyberday).

1. Limiting external interfaces

Hosts are provisioned for one defined function (DMCS, reverse proxy, VPN, monitoring). We do not expand dedicated servers with unrelated workloads. Services run as fixed Docker containers from our secured repo; Ansible prevents multi-role drift. High-risk customer sources can use a dedicated DMCS. Management prefers outbound Management Tool/VPN instead of extra inbound admin interfaces.

2. Limiting ports

Default-deny / whitelist: only approved ports. Typical pattern: HTTPS 443 for intended TLS endpoints (admin IP-restricted); on-prem DMCS mainly needs outbound 443 for monitoring/updates; VPN edge exposes only port 1194 to approved client IPs. Firewall/security-group changes are logged and reviewed; unused listeners are disabled.

3. Limiting devices with external interfaces

Small internet-facing footprint: SaaS on dedicated Hetzner bare metal; on-prem DMCS in DMZ/isolated segment; tooling on private nets. Client-to-client VPN is disabled. New external devices need justification, owner, and rules before go-live; unused public endpoints are removed.

4. Secure and robust systems

Container isolation, TLS/SSH/VPN, encryption at rest, Entra ID/AD where applicable. CIS Benchmarks (Docker, Ubuntu/OpenSCAP, NGINX, GitHub). Dual code review, SonarCloud, Dependabot, Ansible deploys, image integrity checks. Five-layer defense plus Security Center heartbeat monitoring.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.2.j): Limit attack surfaces

Monitoring of technical vulnerability communications

The organization monitors information about technical vulnerabilities of the information systems in use. When relevant technical vulnerabilities are detected, the organization takes action according to the planned operating model.

Description

Continuous monitoring of technical vulnerabilities: The organization regularly checks for technical vulnerabilities in the information systems in use. This ensures timely detection and remediation of potential issues.

Detection of relevant technical vulnerabilities: The organization has set up system probes and intrusion detection systems to identify any relevant technical vulnerabilities. These systems flag potential vulnerabilities, triggering further action according to the established protocol.

Implementation of planned operating model for vulnerabilities: The organization follows a planned operating model when dealing with detected vulnerabilities. This model outlines the steps to be taken immediately upon detection, including risk assessment, mitigation planning, and execution.

Assurance:



Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

DORA RTS Risk management framework - Article 10: Vulnerability and patch management

Monitoring the use of the available capacity

The operation of information systems may depend on certain key resources, such as *server capacity, storage space, data processing capacity, monitoring capacity* or *certain key people*.

The organization has defined key resources and methods for monitoring the use of these key resources. A normal level is also determined for the resources, which is used when assessing the risk of jeopardizing availability due to capacity problems.

Description

Identification of key resources: The organization has identified key resources including server capacity, storage space, data processing capacity, monitoring capacity, and key personnel, which are crucial for the operation of information systems.

Monitoring methods for key resources: The organization has developed specific methods to monitor the usage of these key resources. These methods help in ensuring the resources are optimally utilized and are not under or overburdened.

Assurance:

 Medium

Priority:

Low ↓

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

SOC 2 - A1.1: Evaluation of current processing capacity...

+2 requirements

Performing root cause analysis on security vulnerabilities

The organization establishes a dedicated team and standardized process for root cause analysis of security vulnerabilities, ensuring thorough data gathering, cause identification, collaboration with development teams for solutions, training to prevent recurrence, and continuous improvement of security practices.

Description

D&M have established a dedicated team and standardized process for root cause analysis of security vulnerabilities, ensuring thorough data gathering, cause identification, collaboration with development teams for solutions, training to prevent recurrence, and continuous improvement of security practices.

Assurance:

 **Strong**

Priority:

Normal

Status:

Fully done

Owner:

K K.

Linked requirements:

CIS 18 - 16.3: Perform Root Cause Analysis on Security Vulnerabilities

Personnel support for chosen resilience testing operations

Organization's resilience testing programme is prepared for providing all the necessary supporting expert work for the chosen resilience testing operations. This may include e.g. performance testing, end-to-end testing, penetration testing or source code reviews.

Related resilience testing operations can e.g. include vulnerability scans, other scanning software use, network security assessments, physical security reviews or other kinds of gap analyses.

Description

D&M resilience testing programme is prepared for providing all the necessary supporting expert work for the chosen resilience testing operations.

Assurance:

 **Medium**

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

The Digital Operational Resilience Act (DORA) - Article 25: Testing of ICT tools and systems

Prioritization of identified technical vulnerabilities and remediation goals

The organization must have a clear model for prioritizing identified technical vulnerabilities. The operating model should not be entirely new invention, but should be based on generally accepted practices.

Vulnerabilities should be prioritized based on the risk they pose, the importance of the assets involved, the potential organizational impact, and the urgency (taking into account the CVSS value).

Description**Process: Prioritization of Technical Vulnerabilities and Remediation Goals****Objective:**

To quickly assess and fix security vulnerabilities based on risk level and business impact.

Step 1: Identify Vulnerabilities

- Run regular vulnerability scans (e.g., Nessus, Qualys).
- Check security reports (e.g., penetration tests, threat intelligence).
- Monitor updates from vendors and security advisories.

Step 2: Assess Risk

- Determine how serious each vulnerability is based on:

- **Severity score** (e.g., CVSS rating).
- **Ease of exploitation** (Is it actively exploited?).
- **Business impact** (Does it affect critical systems or data?).
- **Existing protections** (Are there security measures in place?).
- Categorize vulnerabilities as **High, Medium, or Low risk**.

Step 3: Prioritize Fixes

- **High risk** → Fix immediately (within 24 - 72 hours).
- **Medium risk** → Schedule for resolution within a reasonable timeframe (e.g., 30 days).
- **Low risk** → Address during routine maintenance.

Consider downtime, resources, and compliance requirements when scheduling fixes.

Step 4: Implement Fixes

- **Apply patches** where available.
- **Adjust system settings** to remove security weaknesses.
- **Use temporary workarounds** if patches aren't available.

Step 5: Verify & Monitor

- Re-scan systems to confirm fixes worked.
- Keep track of vulnerability remediation progress.
- Regularly review security practices to stay ahead of threats.

Step 6: Report & Review

- Document actions taken.
- Share key updates with management and security teams.
- Continuously improve the process based on lessons learned.

By following these steps, the company ensures a proactive and efficient approach to vulnerability management while staying compliant with ISO 27001.

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

CIS 18 - 18.3: Remediate Penetration Test Findings

Process for managing technical vulnerabilities

The organization has defined a process for addressing identified technical vulnerabilities.

Some vulnerabilities can be fixed directly, but vulnerabilities that have a significant impact should also be documented as security incidents. Once a vulnerability with significant impacts has been identified:

- risks related to the vulnerability and the necessary actions are identified (e.g. patching the system or other management tasks)
- necessary actions are scheduled
- all actions taken are documented

Description

Process for addressing technical vulnerabilities: The organization has delineated a process to address technical vulnerabilities identified within its systems. This procedure is designed with swift and effective responses in mind, to minimise potential security threats.

Direct fixes and incident documentation: While some vulnerabilities can be fixed directly, those with a substantial potential impact are documented as security incidents. The organization acknowledges the need for tracking and properly handling vulnerabilities that may pose significant security risks.

Risk identification and action planning: Upon identifying a vulnerability with significant impacts, the organization promptly identifies the potential risks related to the vulnerability and the necessary actions to be taken. These actions could include system patching or other management tasks aimed at containing and mitigating the risks.

Scheduling necessary actions: Having identified necessary actions, the organization then schedules these actions to ensure a structured and timely response to security vulnerabilities. This organized approach aids in effectively neutralizing security threats.

Documenting actions taken: All actions taken to address significant vulnerabilities are thoroughly documented by the organization. This serves as a crucial record for reviewing and improving security practices, as well as providing evidence of diligent action in response to vulnerabilities.

Assurance:

 Medium

Priority:

High ↑

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.8: Management of technical vulnerabilities...

+16 requirements

Process for vulnerability disclosure

The organization has a process for handling vulnerabilities disclosed by other parties, such as regular users or white-hat hackers.

Typically, this is managed through Vulnerability Disclosure Programs (VDPs) or formal bug bounty programs. These programs allow users to submit vulnerabilities to the organization.

Description

Vulnerability Disclosure Process (VDP) For Data & More and DMCS

1. Purpose

To define how external individuals or organizations can **responsibly disclose security vulnerabilities** in D&M products or infrastructure—especially those affecting **DMCS**—and how D&M responds in a timely, structured, and secure manner.

2. Scope

This process applies to:

- All software and digital products developed or maintained by D&M
- Infrastructure, APIs, and services related to DMCS
- Any security vulnerability, weakness, or exploit with potential risk to users, operations, or systems

3. Reporting Channel (Single Point of Contact)

All vulnerabilities must be reported to:

 support@dataandmore.com

This is the **designated single point of contact** for all security disclosures.

(Optional: D&M may publish a **PGP key** for encrypted submissions.)

4. Responsible Disclosure Guidelines for Reporters

- Provide detailed technical information including:
- Description of the vulnerability
- Affected product, system, or environment
- Reproduction steps or proof of concept (if available)
- Do **not** exploit, publicly disclose, or misuse the vulnerability
- Do not attempt denial-of-service, data exfiltration, or system disruption

D&M encourages ethical disclosure and does not pursue legal action against good-faith researchers acting within these boundaries.

5. Triage & Verification (D&M Internal Steps)

Upon receiving a report:

- **Acknowledgement** is sent to the reporter within **3 business days**
- Security team initiates **triage**, including:
- Reproducing the issue
- Validating scope and severity
- Classifying risk level based on CVSS and business impact
- Coordination with DMCS engineering or infrastructure teams for context

6. Internal Response & Remediation

- Assign owner within the appropriate team (e.g., DMCS engineering)
- Determine remediation strategy:
- Patch development
- Configuration fix
- Temporary workaround
- Follow the Vulnerability Management timelines:
- Critical: fix within 7 days
- High: fix within 14 days
- Conduct **post-remediation verification**

7. External Notifications (if required)

If the vulnerability is:

- **Actively exploited**, or
- Could significantly impact **EU customers or digital service providers**

D&M will notify:

- The **national Coordinating CSIRT**
- The **European Union Agency for Cybersecurity (ENISA)**

This aligns with Articles 11–12 of the **Cyber Resilience Act**.

8. Disclosure to the Public

If the vulnerability has broader implications:

- A **coordinated disclosure timeline** may be agreed upon with the reporter
- D&M will issue a **security advisory**, which may include:
 - Affected product/component
 - Severity and risk summary
 - Remediation guidance or patches
 - Credits to the reporter (with permission)

9. Documentation & Recordkeeping

- Every report is logged in D&M's **Vulnerability Disclosure Register**
- Includes:
 - Dates of report, triage, remediation
 - Communications with reporter
 - Links to patches or advisories issued

10. Continuous Improvement

- Regularly review the VDP process

- Incorporate feedback from reporters and lessons from past disclosures
- Perform periodic audits and tabletop simulations

✓ Summary Checklist for Vulnerability Disclosure

Step Responsibility Timeline

Acknowledge receipt Security Team $\leq$ 3 business days

Triage & validate Security Team $\leq$ 5 business days

Fix & verify Product Teams Based on severity

Notify CSIRT/ENISA (if applicable) CISO / Legal Immediate

Disclose publicly (optional) Comms & Security Agreed upon

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.17: Single point of contact

Process for vulnerability remediation

The organization has defined processes for addressing identified vulnerabilities.

These processes should include at least the following:

- Identifying risks related to the vulnerability and the necessary actions (e.g. patching the system or other management tasks)

- Necessary actions are scheduled
- All actions taken are documented

The organization performs the actions necessary to prevent the vulnerability within the time limit set by the competent cyber incident prevention institution, but no later than 90 days after receiving the information, and informs the competent cyber incident prevention institution about the progress of the vulnerability prevention.

If, due to objective reasons, it is not possible to eliminate the vulnerability within the time limit specified, at the request of the organization, the cyber incident prevention institution may extend the deadline for the elimination of the vulnerability, but not more than 180 days from the moment of submitting the vulnerability detection report, by informing about it in the vulnerability detection report the submitter.

Description

D&M has defined processes for addressing identified vulnerabilities.

These processes should include:

- Identifying risks related to the vulnerability and the necessary actions (e.g. patching the system or other management tasks)
- Necessary actions are scheduled
- All actions taken are documented

The D&M performs the actions necessary to prevent the vulnerability within the time limit set by the competent cyber incident prevention institution, but no later than 90 days after receiving the information, and informs the competent cyber incident prevention institution about the progress of the vulnerability prevention.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.2.a): Known exploitable vulnerabilities

Regular analysis and utilization of information related to information security threats

Organization carries out threat intelligence by analyzing and utilizing collected information about relevant cyber security threats related and corresponding protections.

When analyzing and utilizing the collected threat intelligence information, the following points must be taken into account:

- analyzing how the threat intelligence information relates to to our own operations
- analyzing how relevant threat intelligence information is to our operations
- communicating and sharing information in an understandable form to relevant persons
- utilizing the findings of threat intelligence to determine the adequacy of technical protections, technologies used and information security testing methods for analysis

Description

Conducting threat intelligence: The organization actively carries out threat intelligence by collecting information about potential information security threats related to its operations and identifying protection methods. The aim is to enhance awareness of the threat landscape, allowing for better evaluation of its security level and implementation of adequate control measures.

Multifaceted approach to threat intelligence: When accumulating threat intelligence, the organization takes into account all three levels - strategic threat intelligence (such as information on emerging types of attackers and attacks), tactical threat intelligence (like information about tools and technologies used in attacks), and operational threat intelligence (details of specific attacks).

Setting threat intelligence targets: As part of its threat intelligence principles, the organization sets clear targets for its threat intelligence activities. These targets guide its efforts and lend focus to the objective of identifying specific threat trends and patterns.

Identification and selection of information sources: The organization identifies, verifies, and selects trusted information sources for its threat intelligence activities. The chosen sources further enrich its threat intelligence database, enhancing the reliability and scope of collected information.

Gathering and processing threat intelligence: The organization systematically gathers threat intelligence and processes it for analysis. This includes translation, formatting, and compression of data to enable efficient and comprehensive threat analysis.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 5.7: Threat intelligence...
+7 requirements

Regular monitoring of the vulnerability management process

The technical vulnerability management process is regularly monitored and evaluated to ensure its effectiveness and efficiency.

Description

Regular monitoring of vulnerability management process: The organization continuously monitors its technical vulnerability management process. This involves checking for timely detection, accurate categorization, effective mitigation, and proper documentation of vulnerabilities.

Evaluation of vulnerability management process: The organization evaluates the effectiveness and efficiency of the vulnerability management process on a regular basis. This evaluation includes metrics such as time to detect, time to

mitigate, and the rate of recurring vulnerabilities.

Assurance:

 Medium

Priority:

Low 

Status:

Fully done

Owner:

KH K. Boe Helweg

Linked requirements:

ISO 27001/27002:2022 - 8.8: Management of technical vulnerabilities...

+6 requirements

Regular penetration testing

Static scans on code are the first step in detecting risky vulnerabilities. However, once a service has been deployed, it is vulnerable to new types of attacks (e.g., cross-site scripting or authentication issues). These can be identified by penetration testing.

Description

Initiation of vulnerability detection with static scans: The organization has incorporated static scans on code as the initial step for detecting potential vulnerabilities. This helps identify any inherent flaws at the coding level that may pose security risks.

Awareness of post-deployment vulnerabilities: The organization recognizes that even after deployment, services may be susceptible to novel types of attacks such as cross-site scripting or authentication issues.

Implementation of penetration testing: To identify these post-deployment vulnerabilities, the organization regularly conducts penetration testing. This proactive measure aids in identifying and addressing potential

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 5.36: Compliance with policies, rules and standards for information security...

+11 requirements

Regular testing of the vulnerability management process

The vulnerability management process is regularly tested at intervals specified by the organization to ensure that it is up-to-date, functional, and effective.

Description

Routine testing of vulnerability management process: The organization carries out tests on the vulnerability management process regularly at specified intervals. This routine testing ensures the process remains up-to-date, functional, and effective.

Evaluation using predefined criteria: The organization evaluates the vulnerability management process against a set of predefined criteria. This includes efficiency of vulnerability detection, effectiveness of mitigation measures, timeliness of actions, and accuracy of documentation.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

NIST Cybersecurity Framework V2.0 - ID.IM-04: Incident response and cybersecurity plans...

+3 requirements

Regular vulnerability scanning

The organization regularly conducts a vulnerability scan, which searches for vulnerabilities found on computers, workstations, mobile devices, networks or applications. It is important to scan even after significant changes.

It should be noted that vulnerable source code can be from operating system software, server applications, user applications, as well as from the firmware application as well as from drivers, BIOS and separate management interfaces (e.g. iLo , iDrac). In addition to software errors, vulnerabilities occur from configuration errors and old practices, such as the use of outdated encryption algorithms.

Description

Regular vulnerability scanning: The organization routinely carries out vulnerability scans across various systems, including computers, workstations, mobile devices, networks, and applications. This practice enables the early detection and mitigation of potential vulnerabilities.

Scanning after significant changes: To ensure the utmost security, the organization also performs vulnerability scans after significant changes have been made to any system. This helps in uncovering any potential risks introduced by the changes.

Source code vulnerability awareness: It is recognized by the organization that vulnerable source code can originate from different environments, including operating system software, server applications, user applications, firmware applications, drivers, BIOS, and separate management interfaces (like iLo, iDrac).

Accounting for configuration errors and outdated practices: The organization is aware that vulnerabilities can arise not just from software errors, but also from configuration mistakes and outdated practices, such as the use of obsolete

encryption algorithms. Measures are in place to avoid such pitfalls and stay updated with best practices.

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber Essentials - MWP-02: Automatic file scan by anti-malware software...
+14 requirements

Regularly conducting penetration testing with predefined goals and scope

Penetration testing should have clearly defined goals and scope. The goals may include, e.g., testing continuity plans and capabilities, assessing security controls or identifying security weaknesses. The scope can be defined as follows:

- - Identify critical parts of the information system that should be prioritized during testing.
- - Identify individual systems or components that are so vital they must be excluded from testing.

Vital systems or components that could be excluded, e.g., include those essential for maintaining critical organizational services or those unable to withstand the stress of a penetration test.

During the planning phase, it is important to involve relevant stakeholders in advance. This often means informing external system monitoring providers prior to testing, though it may not be necessary to inform users or system management personnel.

Penetration testing should be conducted regularly, at least annually. It should be performed both from outside the organization's network perimeter and from within. Testing from the outside simulates an external attack (black box and white box), while testing from the inside simulates potential threats from compromised clients/servers or malicious insiders (grey box).

The results of penetration tests should always be documented.

Description

Penetration Testing Policy (ISAE 3402 / ISAE 3000 Aligned)

1. Policy Purpose

To ensure that regular penetration testing is conducted with predefined goals and scope, aiming to proactively identify and mitigate security vulnerabilities that may compromise information assets or operational integrity.

2. Scope

This policy applies to all critical infrastructure, applications, networks, and data processing environments managed internally or by third-party providers. It forms a core part of the organization's information security control framework.

3. Control Objective

Systems and data must be protected from unauthorized access and vulnerabilities through regular penetration testing, aligned with ISAE 3402 / ISAE 3000 assurance reporting.

4. Control Activity

- Regular penetration tests are conducted at least annually or more frequently based on business risk.
- Testing scope is predefined and approved prior to execution.
- Testing covers internal and external systems, authentication mechanisms, APIs, and access controls.
- Findings are documented, prioritized, and tracked to closure.

5. Roles and Responsibilities

Role Responsibility:

- CISO / Security Team Define scope, manage vendors, review reports
- Infrastructure Team Coordinate access and asset information
- Application Owners Support test preparation and remediation
- Compliance/Audit Maintain evidence and map control to ISAE objectives

6. Test Planning and Execution

- Scope and Rules of Engagement (RoE) must be formally documented and approved.
- Testing methodology should align with OWASP, NIST SP 800-115, or CREST standards.
- Types of tests:
 - Black-box (unauthenticated)
 - Grey-box (limited knowledge)
 - White-box (full access)

7. Test Objectives

- Identify exploitable vulnerabilities
- Validate access control mechanisms
- Assess potential for privilege escalation
- Evaluate incident detection and response effectiveness

8. Deliverables

- Scope Document
- Rules of Engagement
- Penetration Test Report (with severity ratings)
- Remediation Plan
- Retest Report (post-fix verification)

9. Control Evidence Requirements

- Approved test scope documents
- Penetration test reports
- Remediation tracking logs (e.g., Jira, ServiceNow)
- Confirmation of retest and resolution

10. Compliance and Audit

This control supports ISAE 3402 / ISAE 3000 Type I and Type II reporting:

- Type I: Design of control exists and is documented.
- Type II: Control operates effectively throughout the audit period, with supporting evidence retained.

11. Review and Update

This policy must be reviewed annually or following major changes to systems or business operations.

12. Exceptions

Any exceptions must be documented, risk assessed, and approved by the CISO or delegated authority.

Assurance:

 Medium

Priority:

High ↑

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 18.2: Perform Periodic External Penetration Tests

Regularly conducting threat-led penetration testing (TLPT)

Organization has a process for regularly conducting threat-led penetration testing (TLPT).

TLPT process fills the following requirements:

1. **Frequency:** Financial entities are required to conduct advanced TLPT by default every three years.

2. **Scope:** Each TLPT must cover several or all critical or important functions of the entity and must be conducted on live production systems that support these functions.
3. **Inclusion of third-party ICT providers:** If critical functions are outsourced to third-party ICT service providers, these providers must be included in the TLPT.
4. **Vulnerability mitigation:** Entities must (in collaboration with third-party providers and testers) apply effective risk management controls to mitigate potential impacts on data, assets, and operations.
5. **Test reporting:** Upon completing the testing, entities must provide a summary of findings and remediation plans to the designated authority.
6. **Tester requirements:** Entities must engage testers as specified in the regulations, using external testers periodically (every three tests) unless classified as significant, in which case only external testers must be used.

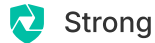
Description

Organization has a process for regularly conducting threat-led penetration testing (TLPT).

TLPT process fills the following requirements:

1. **Frequency:** We are required to conduct advanced TLPT by default every year.
2. **Scope:** Each TLPT must cover several or all critical or important functions of the entity and must be conducted on live production systems that support these functions.
3. **Inclusion of third-party ICT providers:** If critical functions are outsourced to third-party ICT service providers, these providers must be included in the TLPT.
4. **Vulnerability mitigation:** Entities must (in collaboration with third-party providers and testers) apply effective risk management controls to mitigate potential impacts on data, assets, and operations.
5. **Test reporting:** Upon completing the testing, entities must provide a summary of findings and remediation plans to the designated authority.
6. **Tester requirements:** Entities must engage testers as specified in the regulations, using external testers periodically (every three tests) unless classified as significant, in which case only external testers must be used.

Assurance:



Priority:

High ↑

Status:

Fully done

Owner:

DJ D. Junge

Review cycle:

yearly Next review: 05.08.2027

Linked requirements:

The Digital Operational Resilience Act (DORA) - Article 26: Advanced testing of ICT tools, systems and processes based on TLPT

Remediation of vulnerabilities in third-party components

The organization must define policies for vulnerability remediation in third-party components.

When a vulnerability in a component is identified, the component supplier must be contacted to clarify the situation and determine the remediation actions. The organization must define whether to wait for a vendor-led remediation or to develop a remediation independently.

The organization should also consider whether to continue using the component.

Description

Here is a comprehensive and structured **Policy for Vulnerability Remediation in Third-Party Components**, suitable for inclusion in an organization's broader security or software governance framework:

Policy for Vulnerability Remediation in Third-Party Components

1. Purpose

This policy defines the principles and procedures for identifying, evaluating, and remediating vulnerabilities in third-party software components—such as libraries, frameworks, or platforms—used in systems managed by Data & More. It ensures the integrity, confidentiality, and availability of systems that rely on external dependencies.

2. Scope

This policy applies to all third-party components integrated into:

- Production and pre-production systems
- Development and staging environments
- Internal tooling and customer-facing applications

3. Responsibilities

- **Security Team:** Responsible for monitoring threat intelligence feeds and vulnerability databases (e.g., NVD, CVE).
- **Engineering Teams:** Own and remediate vulnerabilities in third-party components used in their systems.
- **Risk Management Team:** Assesses critical vulnerabilities' impact on the business and approves exceptions.

4. Identification of Vulnerabilities

- Vulnerabilities must be identified through:
- Automated tools (e.g., Snyk, Dependabot, Trivy)
- Manual code and dependency reviews
- Public vulnerability databases (CVE, NVD)
- Vendor security advisories

5. Risk Classification

Vulnerabilities will be classified based on their **CVSS score** and business impact:

Risk Level → CVSS Score → Remediation Timeline

Critical 9.0 - 10.0 Within 7 calendar days

High 7.0 - 8.9 Within 14 calendar days

Medium 4.0 - 6.9 Within 30 calendar days

Low 0.1 - 3.9 At the next scheduled update

Note: Risk impact may override CVSS classification based on asset criticality.

6. Remediation Process

1. **Triage:** Engineering teams assess affected systems and validate exposure.
2. **Patch or Upgrade:** Apply the vendor patch, upgrade to a fixed version, or replace the component.
3. **Mitigation:** If immediate remediation is not possible, a compensating control must be implemented and documented.
4. **Verification:** Conduct testing in staging/pre-production to validate resolution.
5. **Documentation:** Maintain remediation status and evidence in a central vulnerability management system (Hubspot).

7. Exceptions

- If remediation is not feasible within the prescribed timeline:
- An exception must be submitted to the Risk Management Team.
- The request must include: risk justification, planned mitigations, and estimated resolution date.
- Exceptions must be re-evaluated every 30 days.

8. Compliance and Auditing

- Quarterly audits will be performed to assess compliance.
- Non-compliance will be escalated to the CISO and the relevant product leadership.

9. References

- [NIST SP 800 - 40: Guide to Enterprise Patch Management]
- [OWASP Dependency - Check Guidelines]
- [CVE Details: <https://cvedetails.com>]
- Internal Vulnerability Management Playbook

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.6: Vulnerabilities in third party components

Secure configuration of products

The organizations manages and monitors the safe configuration of provided products and system components. We configure products to be secure by default, unless otherwise agreed in advance between the manufacturer and the customer in relation to a customized product. The configuration includes the possibility to reset the product to its original state. We keep track of the configurations we use and how they changed over time.

Description

D&M manages and monitors the safe configuration of provided products and system components.

We configure products to be secure by default and the customer in relation to a customized product. We keep track of the configurations we use and how they changed over time.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.2.b): Secure configuration

Selecting and tracking data sources for vulnerability information

Information sources for software and other technologies have been consciously identified to identify and maintain information about technical vulnerabilities that are relevant to us (e.g. authorities or hardware and software manufacturers). Data sources are evaluated and updated as new useful sources are found.

Vulnerabilities can be found directly in the vendor systems we exploit or in the open source components exploited by many of our systems. It's important to keep track of multiple sources to get the essential information obtained.

Description

Identification of Information sources: The organization has identified diverse information sources such as authorities or hardware and software manufacturers. These sources are handpicked to identify and keep track of any information about potential technical vulnerabilities.

Routine evaluation of data sources: The organization has put in place a mechanism to periodically evaluate the effectiveness and relevance of these data sources. The data sources are updated whenever new and useful sources are identified.

Vendor systems vulnerability tracking: The organization has come up with a way to find vulnerabilities directly from the vendor systems it uses. This is done by either staying informed about the updates from the vendor or using specific tools for vulnerability detection.

Open source components exploitation monitoring: The organization has mechanisms to identify potential vulnerabilities from the open source components. It makes regular checks on these open source components because these are used by many of the organization's systems.

Multi-source tracking approach: Realising the importance of sourcing information from multiple places, the organization uses a multi-source tracking approach. The essential information obtained helps in dealing with any potential threats.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

sc S. Colak

Linked requirements:

ISO 27001/27002:2022 - 8.8: Management of technical vulnerabilities...

+3 requirements

Separation of critical environments

Isolate technical environments where the consequences can be very damaging.

Description

Technical environment isolation: The organization has isolated technical environments that have potential to cause severe damage.

Damage assessment: The organization has implemented a process to predict the potential damage that could be caused in various technical environments. This helps in understanding which systems need to be isolated.

Deployment of additional security measures: In the identified high-risk environments, the organization has deployed additional security measures to minimize the likelihood of a major security incident.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 8.22: Segregation of networks...

+4 requirements

Sharing threat intelligence

Organization should share threat intelligence information actively with other organizations to improve its own threat awareness.

Description

Establishment of threat intelligence sharing networks: The organization has established networks for sharing threat intelligence information with other organizations. This exchange improves the organization's understanding of the threat landscape and helps others too.

Active participation in threat intelligence forums: The organization is an active participant in various threat intelligence forums and communities. These platforms provide valuable insights and help the organization improve its own threat awareness.

Assurance:

 Medium

Priority:

Low 

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 5.7: Threat intelligence...

+2 requirements

Software Bill of Materials (SBOM)

The organization documents the software dependencies, including libraries, drivers, and other components, for its products with digital elements. The documentation should be machine-readable, e.g. in JSON or XML. The documentation may be based on the list of dependencies in the development environment, a product description by the supplier, or a scanning tool.

Description

D&M documents the software dependencies, including libraries, drivers, and other components, for its products with digital elements.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

K k.

Linked requirements:

The goals of threat intelligence and the collection of information related to information security threats

Organization carries out threat intelligence by gathering information about information security threats related to its operations and how to protect against them. The goal is to increase awareness of the threat environment, so that own security level can be better evaluated and adequate control measures implemented.

When collecting threat intelligence, all three levels must be taken into account:

- strategic threat intelligence (e.g. information on the growing types of attackers and attacks)
- tactical threat intelligence (e.g. information about tools and technologies used in attacks)
- operational threat intelligence (e.g. details of specific attacks)

Principles related to threat intelligence should include:

- setting targets for threat intelligence
- identification, verification and selection of information sources used in threat intelligence
- gathering threat intelligence
- data processing for analysis (e.g. translation, formatting, compression)

Description

Conducting threat intelligence: The organization actively carries out threat intelligence by collecting information about potential information security threats related to its operations and identifying protection methods. The aim is to enhance awareness of the threat landscape, allowing for better evaluation of its security level and implementation of adequate control measures.

Multifaceted approach to threat intelligence: When accumulating threat intelligence, the organization takes into account all three levels - strategic threat intelligence (such as information on emerging types of attackers and attacks), tactical threat intelligence (like information about tools and technologies used in attacks), and operational threat intelligence (details of specific attacks).

Setting threat intelligence targets: As part of its threat intelligence principles, the organization sets clear targets for its threat intelligence activities. These targets guide its efforts and lend focus to the objective of identifying specific threat trends and patterns.

Identification and selection of information sources: The organization identifies, verifies, and selects trusted information sources for its threat intelligence activities. The chosen sources further enrich its threat intelligence database, enhancing the reliability and scope of collected information.

Gathering and processing threat intelligence: The organization systematically gathers threat intelligence and processes it for analysis. This includes translation, formatting, and compression of data to enable efficient and comprehensive threat analysis.

Assurance:

 Medium

Priority:

High 

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

ISO 27001/27002:2022 - 5.7: Threat intelligence...

+4 requirements

TLPT tester requirements

The testing organization used for threat-led penetration testing should meet at least the following requirements:

- Highest suitability and reputability for the task
- Have technical and organisatory capabilities especially in threat intelligence, penetration testing and red teaming
- Are certified in a EU member state

- They provide an audit report in relation to management of risks related to carrying out the testing
- They are fully covered by relevant insurances including against risks of misconduct and negligence

In the case of using internal testers along with the list above they should be:

- Approved by competent authority
- Authority has confirmed the organisation has sufficient resources to perform the testing and conflicts of interest are avoided
- Threat intelligence provider must be external from the entity

In contracts with the tester management of results and any data processing do not create risks to the organization.

Description

The organization D&M used for threat-led penetration testing meet the following requirements:

- Highest suitability and reputability for the task
- Have technical and organisatory capabilities especially in threat intelligence, penetration testing and red teaming
- Are certified in a EU member state
- They provide an audit report in relation to management of risks related to carrying out the testing
- They are fully covered by relevant insurances including against risks of misconduct and negligence

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

The Digital Operational Resilience Act (DORA) - Article 27: Requirements for testers for the carrying out of TLPT

Use of vulnerability scanning and attack tools

The organization should use vulnerability scanning tools as the main tool for regular vulnerability scanning process.

In addition organization should use attack tools to test those vulnerabilities found with the scanning tool.

Description

D&M use vulnerability scanning tools as the main tool for regular vulnerability scanning process.

Assurance:

 Strong

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

Cyber resilience act - Article 13.1(.2.a): Known exploitable vulnerabilities

Validation of security measures after penetration testing

The organization should after a penetration test:

- Review the findings from the test and understand the vulnerabilities that might have been exploited

- Asses the current security measuers and determine their effectiveness against the techniques used in the penetration test
- Modify the rulesets on firewalls, IDS/IPS and other security measuers to address possible shortcomings
- Enhance detection measures based on the findings
- Implement additional controls if needed
- Retest according to the penetration testing program

Description

1. Purpose

This document outlines the validation process for security measures following penetration testing. It ensures that identified vulnerabilities are properly remediated and verified in alignment with ISAE 3402 / ISAE 3000 assurance requirements.

2. Scope

Applies to all systems, applications, and infrastructure components that have undergone penetration testing. The validation process must be completed before closure of the test cycle.

3. Objectives

- Ensure all remediation activities have effectively addressed identified vulnerabilities.
- Provide documented proof of validation for audit and compliance purposes.
- Maintain continuous security assurance and control effectiveness.

4. Validation Process Steps

1. Review of Findings:

- Analyze severity and impact of each finding from the penetration test report.

1. Remediation Implementation:

- Responsible teams implement fixes and apply necessary configuration changes.

1. Retesting:

- Retesting is conducted to confirm that vulnerabilities have been mitigated.

- Testing may be performed by internal security staff or independent third parties.

1. Peer Review (Optional):

- Secondary verification or peer review to ensure impartiality and completeness.

1. Closure Sign - Off:

- CISO or Security Team formally approves closure of critical/high-risk issues.

1. Documentation and Archiving:

- Retest results and evidence are archived alongside the original test reports.

5. Control Evidence Requirements

- Retest Reports
- Remediation Implementation Logs (e.g., change requests, tickets)
- Screenshots or logs showing resolved vulnerabilities
- Closure Sign - Off Forms (for critical/high-risk issues)
- Peer Review Logs (if applicable)

6. Audit and Compliance

This process supports ISAE 3402 Type II validation by providing evidence of control operation across the audit period. The validation phase proves not only the design but the **effectiveness** of the control remediation process.

7. Review and Update

This document must be reviewed annually or following any major change to the penetration testing or remediation process.

Assurance:

 Medium

Priority:

Normal

Status:

Fully done

Owner:

DJ D. Junge

Linked requirements:

CIS 18 - 18.4: Validate Security Measures

Employee guidelines

Employee guidelines related to secure development describe the rules that need to be followed when writing new code, testing or treating vulnerabilities.

Secure coding

Using production data for testing

I conduct all testing in a separate development or testing environment. I don't do testing in a production environment and I don't use production data unless it is completely mandatory. In these situations, I ask my supervisor for approval for the use of the testing use of production environment and production data.

Owner:

DJ D. Junge

Guideline acceptance:

9/12 accepted

